

Active Directory Attacks : LLMNR / NBT-NS Poisoning

 medium.com/@AnisO./active-directory-attacks-llmnr-nbt-ns-poisoning-and-relay-5767f81639a6

Anis Ouersighni

January 9, 2024

As I am currently enrolled in the Practical Ethical Hacker course on the TCM Academy Platform, which I highly recommend, I have decided to share some of my learning notes about Active Directory.

In this article we'll look at how LLMNR/NBT-NS poisoning works, what impact the attacks can have and quick fixes to defend your domain against this threat.

Let's Start :

While many organizations are adopting cloud-based services and moving away from on-premises infrastructure, a large proportion of IT setups are **still** reliant on **Window's Active Directory (AD) Domain Services** somewhere within their network. Active Directory environments can become a playground for attackers, especially with certain misconfigurations.

Once an attacker breaches an AD administered local network, they will want to gain as much privilege on the domain as quickly and quietly as possible. LLMNR/NBT-NS poisoning is just one of the attacks used to make this happen.

What are the LLMNR and NBT-NS protocols?

Link-Local Multicast Name Resolution (LLMNR) and NetBIOS Name Service (NBT-NS) are two **name resolution services** that Windows machines use **to identify host addresses on a network when DNS resolution fails or when a DNS server is not available**.

LLMNR and NetBIOS are **enabled by default on modern Windows computers**.

How the Protocols Work :

When a user requests a named resource, the name of this resource needs to resolve to an IP address so that the user's computer knows where to send the network traffic. To resolve the name, the user's computer will try to take the following actions in order of priority:

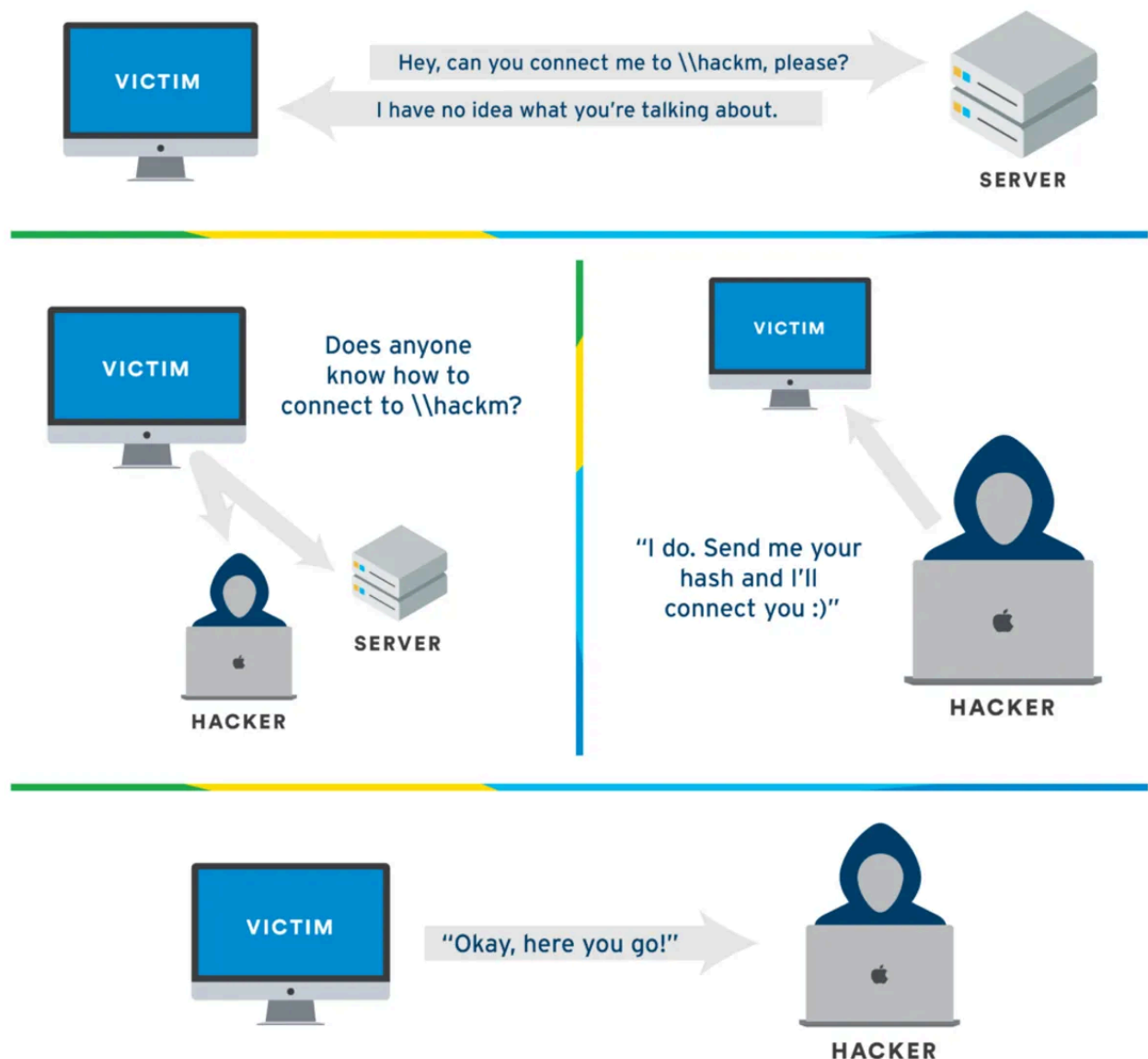
1. Check if the name resolves to the computer itself (localhost).
2. Check to see if the name is in the cache or manually specified in the system's hosts file (C:\Windows\System32\drivers\etc**hosts**)
3. Send a lookup request to the configured DNS server.
4. Broadcast an LLMNR name query to all machines on the local network.
5. Broadcast an NBT-NS name query request to all machines on the local network.

The LLMNR and NBT-NS queries will be **sent to all other hosts on the local network, asking them to respond if they know the IP of the hostname being queried.**

HOW DOES THE ATTACK OCCUR :

Attackers can exploit this and will respond with their own IP address to direct subsequent network traffic for the requested resource to their machine.

Press enter or click to view image in full size



Here, the victim mistyped the name of the shared-disk to access (hackm rather than hackme), or more commonly does a Google search straight from the URL bar of their web browser (come on, we all do it).so the DNS will fail to resolve it. As a result, the victim will send a LLMNR broadcast query to all hosts within the network, demanding a resolution of the host. In this situation, the attacker will be listening through "responder" and will poison the response to claim that he is the demanded host. When a computer receives a response from a host running Responder, the PC ends up giving out its NTLM hash, which can be crack offline, via something like hashcat.

How does LLMNR and NBT-NS poisoning work?

To begin the attack, we start an LLMNR/NBT-NS poisoner such as **Responder**.

Responder can **listen for the LLMNR/NBT-NS queries being broadcast** on the local network and by default also **sets up several different servers**, most notably **SMB**. These will be used to receive authentication requests after the poisoning.

NB :

The link between LLMNR and SMB is that LLMNR can be used to resolve the names of hosts running SMB services (SMB runs generally on port 445) on the local network. When a host wants to access resources shared via SMB on another host, it may use LLMNR to resolve the name of the SMB server to its IP address, enabling communication and access to shared resources.

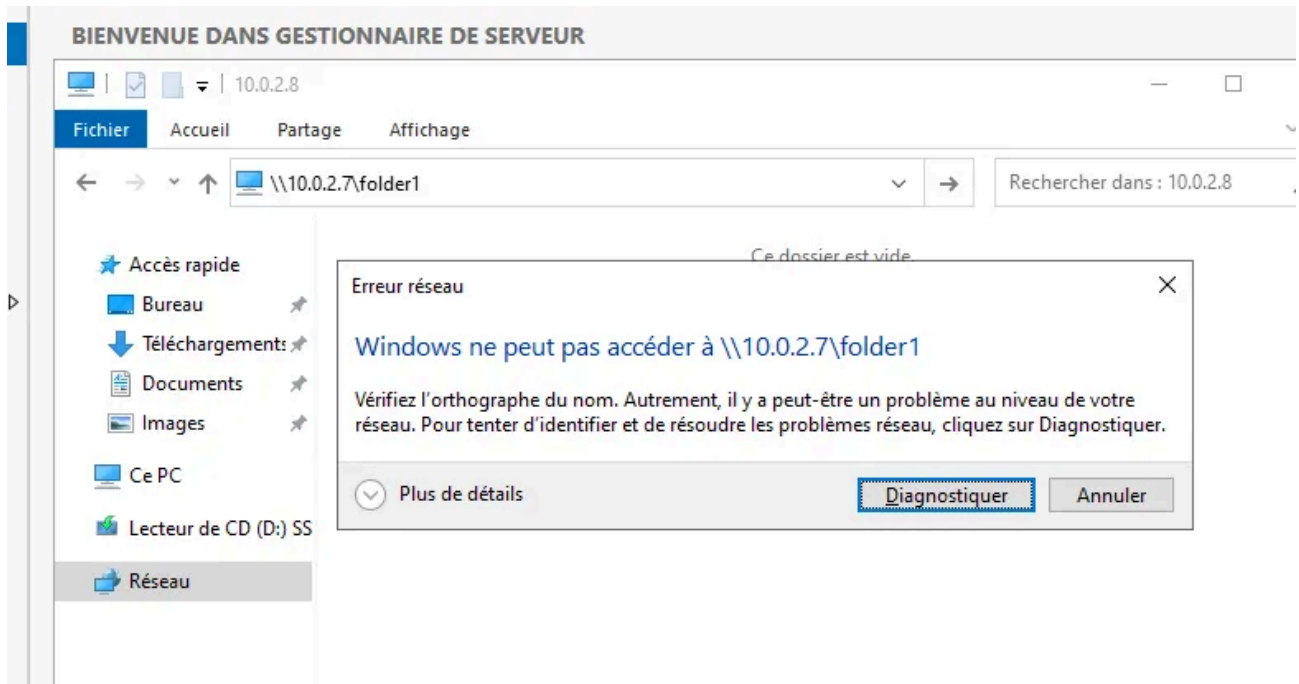
STEPS:

Step 1: Run Responder

`sudo python3 /usr/share/responder/Responder.py -I eth0 -dvw`

We run responder at first may be in the morning or after the lunch because it needs a lot of traffic. We run this before any nmap scan or nessus scan.

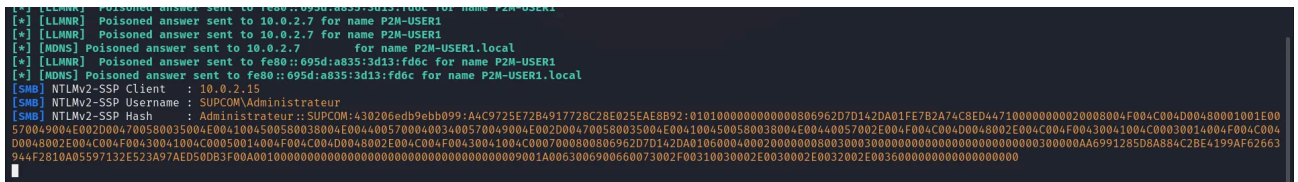
Press enter or click to view image in full size



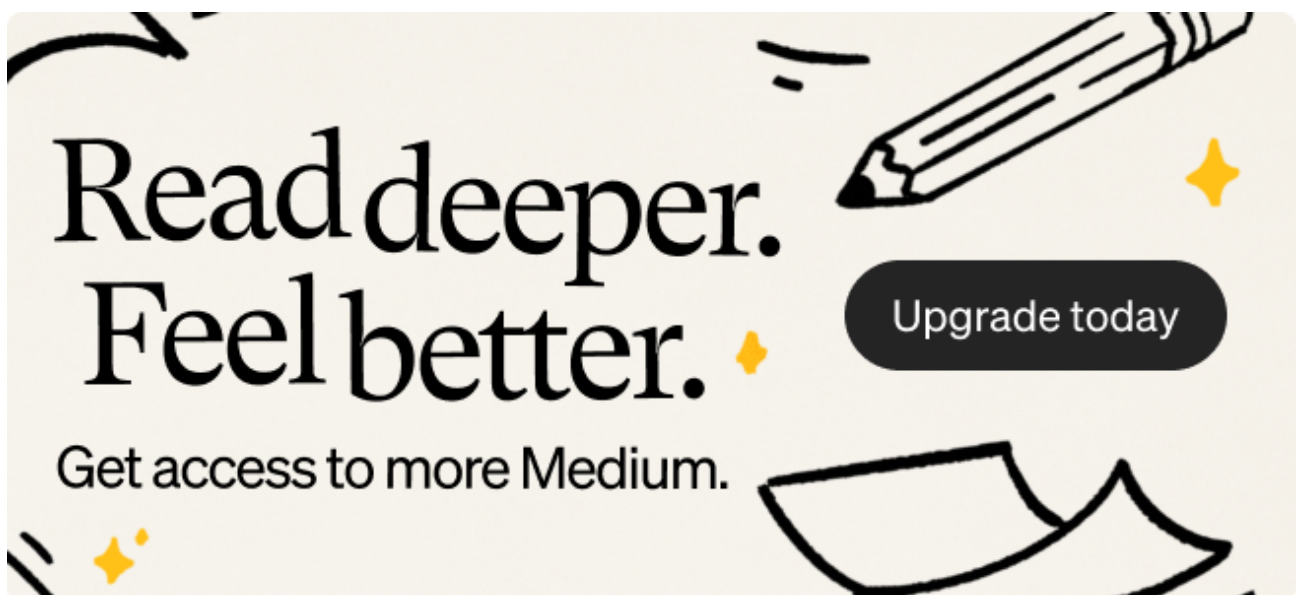
Catch it !

Let's check our Responder !

Press enter or click to view image in full size



We caught and poisoned the Server Administrator, with IP @ = 10.0.2.15, that tried to access the mistyped source folder.



Press enter or click to view image in full size

Once captured, the hashes will be stored inside the Responder/logs directory. You can use the following commands to extract unique hashes and store them into a file named ntlm-hashes.txt.

```
for user in `strings /usr/share/responder/logs/Responder-Session.log | grep
"NTLMv2-SSP Hash" | cut -d ":" -f 4-6 | sort -u -f | awk '{ $1=$1 };1`
do
echo "[*] search for: $user";
strings /usr/share/responder/logs/Responder-Session.log | grep "NTLMv2-SSP Hash" |
grep -i $user | cut -d ":" -f 4-10 | head -n 1 | awk '{ $1=$1 };1' >> ntlm-hashes.txt
done
```

[illegible]

NB : It is recommended to run hashcat on your local machine rather than on your VM. This is because your VM will use the CPU, while your host machine can utilize the GPU for better performance.

6/9

Press enter or click to view image in full size

```
(jerbi@JERBI)-[~/ActiveD/Tools/responder]  
$ hashcat -m 5600 ntlm-hashes.txt /usr/share/wordlists/rockyou.txt --force
```

And congratulations! You have now obtained the passwords for the “Administrateur” DC and the “ETUDIANT2” accounts! 🤗🎉👏

Final Stage of the Article :

What can we do To Mitigate this ?!



There are several steps we can take to combat the effectiveness of Responder:

1. Have effective anti-virus

An effective anti-virus can natively block LLMNR and NetBIOS Server Name broadcast requests, thus preventing credential harvesting. As far as I have been able to find, Windows Defender does **not** have this capability. Your best is to invest in a good AV vendor solution.

2. **Disable LLMNR/NetBIOS Broadcast** The simplest way to defend against LLMNR/NBT-NS poisoning is to disable both LLMNR and NBT-NS completely. For networks that use an ordinary DNS server for name resolution, disabling LLMNR and NBT-NS should have no adverse effects, and by disabling these services you will have closed a prominent security hole.

DISABLE LLMNR

Open ‘Group Policy Management’ on the domain controller.

Add a new GPO (Forest -> Domains -> Your Domain -> Group Policy Objects and Right Click -> New)

You can name the new GPO whatever you like but we've called it 'LLMNR Disabled'.

Right Click the new GPO and select 'edit'.

Go to Computer Configuration -> Policies -> Administrative Templates -> Network -> DNS Client

Double click 'Turn off multicast name resolution' and select 'Enabled'.

Click 'Apply' and then 'OK'

DISABLE NBT-NS

Go to Control Panel -> Network and Internet -> Network and Sharing Centre -> Change Adapter Settings

Right click the network interface in use and choose 'Properties'.

Double click 'Internet Protocol Version 4 (TCP/IPv4)' and then click 'Advanced'

Go to the 'WINS' tab, click 'Disable NetBIOS over TCP/IP' and then click 'OK'.

That's it for this Article, I hope this helped 🙏.
